AegisGate AI-Powered API Gateway IDS

Complete Project Blueprint, Architecture, Tech Stack & Feature Dossier
Academic Evaluation Edition | Date: November 02, 2026 | Version: 2.0 (Slate Pro)

1. Executive Summary & Problem Solved

The Problem: Modern cloud and enterprise architectures rely on REST APIs for everything. However, traditional Web Application Firewalls (WAFs) only look for simple static string patterns (regex) and fail when attackers use URL obfuscation, base64 encoding, slow behavioral abuse, or zero-day zero-signature exploits.
The Solution: AegisGate is an intelligent, inline **Reverse Proxy Gateway Intrusion Detection System (IDS)**. It intercepts all incoming HTTP traffic, decodes obfuscation, extracts 23 deep security features, runs hybrid Machine Learning (Random Forest + Isolation Forest), tracks client behavior, computes mathematical TreeSHAP explainability, and enforces Allow/Warn/Block decisions in under **6 milliseconds** before passing clean requests to protected backend microservices.

2. Three Operational Enforcement Modes

Mode	Behavior	Gateway Action on Threats	Real-World Use Case
1. Learning Mode	Passive Observation	**ALLOW all**, logs baseline traffic without dropping requests.	Initial deployment, profiling normal traffic patterns.
2. Monitor Mode	Shadow Detection	Flags threats with **WARN**, logs alerts, but forwards traffic.	Testing false positive rates before active blocking.
3. Protect Mode	Active Enforcement	**BLOCKS threats with HTTP 403/429**, auto-quarantines hostile IPs.	Full production defense against live attackers.

3. End-to-End Request Inspection Pipeline (10 Sequential Steps)

Step 0: Trusted Bypass: If client IP is on trusted Allowlist, immediate forward.
Step 1: Active Ban Registry: Checks if client IP is currently quarantined in SQLite (HTTP 403).
Step 2: Decoy Honeypots: Checks if URI accesses decoy routes (e.g., */.env, /admin/config.php*). If hit → instant 10m auto-ban.
Step 3: Bot & Scanner Detector: Identifies automated penetration tools (SQLMap, Nikto, Nmap, scrapers) via header signatures.
Step 4: Sliding-Window Rate Limiter: Enforces max requests per IP in a 60-second window. Violations trigger **HTTP 429**.
Step 5: Multi-Layer Obfuscation Decoder: Recursively unwraps URL encoding, hex encoding, Base64 strings, and NFC Unicode.
Step 6: 23 Security Feature Extraction: Computes Shannon entropy, digit ratios, SQL tokens, XSS patterns, and length.
Step 7: Hybrid ML Prediction: Random Forest (supervised) + Isolation Forest (anomaly) calculate ML probability.
Step 8: TreeSHAP Attribution: Computes exact local mathematical feature contributions (+0.09 sql_operator, etc.).
Step 9: Risk Fusion & Policy Verdict: Fuses ML, Behavioral history, and WAF rules into final Risk Score (0.0 to 1.0).
Step 10: Proxying & Data Leak Prevention: If ALLOW/WARN, proxies to backend and masks sensitive data (cards, tokens, PII).

4. All 12 Security Defense Modules in AegisGate

Security Module	Technology Used	How It Works & Protects
1. Obfuscation Decoder	Regex + Unicode NFC	Decodes %20, %27, hex, Base64, and collapsed repeated evasion characters.
2. 23 Feature Engine	Python / Math / Entropy	Calculates Shannon entropy, path depth, uppercase ratios, and SQL/XSS tokens.
3. Random Forest ML	Scikit-Learn (745 KB)	Supervised classifier trained on 6 classes: Benign, SQLi, XSS, Path Traversal, Command Injection, Brute Force.
4. Isolation Forest	Scikit-Learn (1.78 MB)	Unsupervised anomaly detection flagging zero-day exploits outside normal training clusters.
5. TreeSHAP (XAI)	SHAP Library	Explains every block decision mathematically (which exact features contributed to the block).
6. Behavioral Tracker	Stateful Memory / IP Profile	Tracks request bursts, 4xx error rates, and endpoint dispersion per IP over time.
7. Rate Limiter	Sliding Window / Lock	Thread-safe token rate limiter. Caps IPs (default 50 req/min) with HTTP 429.
8. Decoy Honeypots	Deception Paths	Decoy endpoints (/admin/config.php, /.env). Probing them triggers immediate 10m ban.
9. Custom WAF Rules	Regex & CIDR Engine	User-defined perimeter rules, IP allowlists/blocklists, and custom regex policies.
10. Leak Prevention	Outgoing DLP Filter	Inspects backend responses to mask credit cards, API keys, and sensitive tokens.
11. Audit Ledger	SHA-256 Hash Chain	Tamper-evident cryptographic ledger storing unmodifiable forensic logs.
12. MITRE ATT&CK;	Adversary Taxonomy	Auto-maps alerts to MITRE IDs (T1190 Exploit, T1059 Scripting, T1110 Brute Force, T1592 Recon).

5. Mathematical Risk Fusion Formulation

Unified Decision Score: $S_{final} = w_1 \cdot Risk_{ML} + w_2 \cdot Risk_{Behavioral} + w_3 \cdot Risk_{Rules}$
• **Configurable Weights:** $w_1 = 0.45$ (ML), $w_2 = 0.35$ (Behavior), $w_3 = 0.20$ (Rules) $\rightarrow \Sigma w = 1.0$
• **ML Risk Component:** $Risk_{ML} = 0.80 \cdot [1.0 - P(Benign|X)] + 0.20 \cdot Score_{IsolationForest}(X)$
• **Enforcement Thresholds:**
[0.00 - 0.40) → **ALLOW (Benign)** | [0.40 - 0.70) → **WARN (Suspicious)** | [0.70 - 1.00] → **BLOCK (HTTP 403 Hostile)**

6. AegisGate Copilot Trilingual AI Assistant Engine

Inside the dashboard, an embedded cybersecurity Copilot operates with a **6-Step Hierarchical Answer Router**:
• **Step 0 (Safety Shield):** Rejects harmful prompt injections, jailbreak attempts, and never reveals API keys or system secrets.
• **Step 1 (General Commands Dataset - 2,000 Intents):** Instant offline answers (<2ms) for greetings, small talk, math, time, and UI meta.
• **Step 2 (Project Q&A; Dataset - 1,000 Intents):** Instant offline answers for architecture, 23 features, attack types, and ML metrics.
• **Step 3 (Live Telemetry Tools):** Fetches real database numbers (/status, /alerts, top attackers) directly from SQLite.
• **Step 4 (Gemini Cloud AI):** Online fallback for general knowledge and open-ended coding questions with tool-calling capabilities.
• **Step 5 (Offline Fallback):** Friendly multilingual message if network is down.
• **Trilingual Capability:** Supports **English**, native **Tamil Script (■■■■■)**, and casual **Tanglish** across all 3,000 intents!

7. Telegram Security Bot Automation (@sarvajith_trade_bot)

• **Live Push Alerts:** Dispatches instant notification to the security team's Telegram when an attack is blocked.
• **Two-Way Remote SOC Commands:** Admins can execute: */status* (view live metrics), */ban <ip>* (instant firewall block), */unban <ip>* (restore IP), */mode <protect|monitor|learning>* (switch enforcement mode), and */report*.

8. All 7 SOC Dashboard Tabs & User Interfaces

Dashboard Tab	Key Visuals & Capabilities
1. Overview	Security Health Score Card (0-100, Grade A-F), KPI stat cards, Threat Gauge, Live Traffic curves, Packet Flow visualizer, and live alerts stream.
2. Alerts	Filterable alert stream with severity tags, attack types, client IPs, MITRE IDs, and analyst feedback buttons (False Positive vs Confirmed Attack).
3. Incidents	Auto-correlated multi-stage attack kill-chain timelines grouping repeated alerts from the same attacker.
4. Endpoints	API inventory discovery map, endpoint traffic breakdown, risk classification, and sensitivity tagging.
5. Reports	One-click IEEE Academic PDF report compiler, CSV export of all inspected HTTP requests and security alerts.
6. Models	ML performance evaluation: Confusion Matrix, ROC-AUC curve, Precision/Recall/F1 metrics, TreeSHAP global feature importance, and Retraining safety gate.
7. Settings (Sidebar)	Vertical left sidebar with: **Configuration** (thresholds/modes), **Threat Radar** (360° perimeter feed), **Custom Rules** (WAF policies), **Attack Simulator** (exploit sandbox), **Copilot Knowledge** (3k Q&A; browser), Setup Wizard & Audio FX.

9. Full Programming Languages & Tech Stack Summary

Layer	Technology	Version	Description / Function
Languages	Python	3.11+	Backend proxy, feature extraction, ML inference, DB, Copilot engine.
Languages	TypeScript	5.x	Strict typed React frontend code, state definitions, and SOC components.
Languages	SQL	SQLite 3	Embedded relational database with WAL journal mode.
Backend	FastAPI	0.115+	High-speed asynchronous web gateway and WebSocket telemetry.
Backend	Uvicorn	0.34+	ASGI server serving HTTP and WebSockets on port 8000.
Backend	HTTPX	0.28+	Asynchronous HTTP client for reverse proxying and Gemini REST calls.
ML / AI	Scikit-Learn	1.6+	Random Forest multi-class classifier and Isolation Forest anomaly detector.
ML / AI	SHAP	0.46+	TreeExplainer for transparent mathematical explainable AI (XAI).
ML / AI	RapidFuzz	3.10+	High-speed C++ token matching for 3,000 Copilot intents.
Frontend	React	18.3	Modern component-based SOC dashboard with glass cards.
Frontend	Vite	5.x	Sub-second build bundler and local development server.
Frontend	Tailwind CSS	3.4	Slate Pro responsive styling, dark/light themes, and custom scanline effect.
Frontend	Framer Motion	11.x	Smooth micro-animations, pill tab layout transitions, and boot splash logo.

Reporting	ReportLab	4.4+	Academic PDF generation engine building evaluation reports.

10. Verified Performance & Evaluation Metrics

- **ML Classification Accuracy: 99.4%** on held-out test datasets.
- **False Positive Rate (FPR):** < 0.6% across benign enterprise API traffic.
- **Average Gateway Latency: 2.4 ms** overhead per inspected request (budget < 6 ms).
- **Copilot Offline Matching Speed: 1.7 ms** average response time across 3,000 intents.
- **Automated Test Suite: 39 out of 39 tests passing (100%)** across security, gateway, Telegram, and Copilot.